

API CONTRACT

AI Coding Instructions - Analytic & Reporting Dashboard Divisi

TUJUAN DOKUMEN

Mengunci bentuk API, otorisasi, scope data, state transition, error, audit, dan aturan kerja AI. Dokumen ini adalah jembatan terakhir sebelum coding dimulai.

Parameter	Keputusan
Basis	PRD v0.4 + UI/UX v0.2 + ARD v0.3 + Data Dictionary v0.2 + UAT v0.1 + Backlog v0.1
Stack	TypeScript, React, NestJS, Prisma ORM, PostgreSQL
Protocol	REST JSON pada /api/v1; multipart hanya untuk upload file
Scope awal	Manager Minimarket; omzet, rekonsiliasi, target, performa, workforce read-only
Status	Baseline implementasi; keputusan terbuka tidak boleh ditebak

BATAS PENTING

Kontrak ini belum mengesahkan format ekspor SobathR, komponen payroll, rumus omzet final, atau mekanisme autentikasi produksi. Bagian tersebut tetap OPEN/BLOCKED sampai bukti atau keputusan tersedia.

Cara memakai: pilih satu Backlog ID, temukan endpoint dan capability terkait, lalu gunakan prompt modul pada bagian 14.

1. Contract Governance

1.1 Urutan Sumber Kebenaran

1. Keputusan bisnis tertulis dan decision log terbaru.
2. PRD v0.4 untuk scope, peran, dan acceptance produk.
3. UI/UX v0.2 untuk screen state dan microcopy.
4. ARD v0.3 untuk boundary modul, keamanan, dan pola request.
5. Data Dictionary v0.2 untuk model, enum, constraint, dan tipe data.
6. UAT v0.1 untuk perilaku yang harus dibuktikan.
7. Backlog v0.1 untuk unit kerja dan dependensi implementasi.
8. Dokumen ini untuk bentuk transport API dan aturan AI coding.

CONFLICT RULE

Jika dua dokumen bertentangan, jangan memilih diam-diam. Catat konflik, dampak, dan pemilik keputusan; tandai task BLOCKED sampai ada keputusan.

1.2 Status Kontrak

Label	Makna	Boleh dikodekan?
LOCKED	Telah disepakati dan diuji sebagai kontrak	Ya
BASELINE	Pilihan teknis awal yang dapat direvisi terkontrol	Ya, dengan test
OPEN	Keputusan belum disahkan	Hanya interface/config placeholder
BLOCKED	Data/otoritas belum tersedia	Tidak untuk logic produksi

1.3 Keputusan yang Masih Terbuka

- Mekanisme autentikasi produksi, masa sesi, dan reset akun.
- Rumus gross/net termasuk pajak, diskon, refund, rounding, dan mata uang.
- Contoh ekspor, kode status, timezone, dan unique employee key SobatHR.
- Komponen agregat payroll yang boleh terlihat oleh BOD.
- Provider file storage, queue, retention, RPO/RTO, dan SLA freshness.

2. Global REST Contract

Item	Baseline
Base URL	/api/v1
Content type	application/json; multipart/form-data untuk file
Identifier	UUID string
Tanggal/waktu	ISO 8601; timestamp disimpan UTC
Bulan	YYYY-MM
Uang	Decimal string + currency; jangan JSON float
Pagination	page, per_page; meta.page, meta.per_page, meta.total
Filter	period, division_id, outlet_id, status sesuai endpoint
Version conflict	version/updated_at atau If-Match; finalisasi setelah strategi dipilih
Trace	Setiap response/error membawa trace_id

2.1 Success Envelope

```
{
  "data": { ... },
  "meta": { "trace_id": "uuid", "data_period": "2026-08", "source": "EXCEL", "last_synced_at": "...",
  "completeness": "COMPLETE" },
  "links": { "self": "/api/v1/..." }
}
```

2.2 Error Envelope

```
{
  "error": {
    "code": "VALIDATION_ERROR",
    "message": "Periksa field yang ditandai.",
    "fields": [{ "field": "outlet_id", "code": "OUTLET_NOT_FOUND", "message": "Kode outlet tidak aktif."
  }],
  "trace_id": "uuid"
}
```

ATURAN RESPONSE

Jangan mengirim stack trace, SQL, path file, payload payroll, NIK, rekening, diagnosis, atau secret kepada client maupun log.

3. Identity, Capability & Data Scope

3.1 Role Bukan Permission

SECURITY RULE

Role memberi kumpulan capability; setiap endpoint tetap memeriksa capability dan scope di server. Menu tersembunyi bukan kontrol keamanan.

Role	Scope dasar	Larangan penting
BOD	Seluruh divisi/outlet untuk fitur yang diizinkan	Tidak mengedit skor/target secara langsung; payroll hanya agregat
Superadmin	Seluruh data sesuai capability eksplisit	Tidak otomatis boleh self-approve atau melihat payroll
HRD	Workforce sesuai kebijakan perusahaan	Tidak otomatis mengakses omzet/payroll summary
Manager	Divisi/outlet assignment aktif	Tidak mengakses scope lain atau payroll
User	Employee identity sendiri	Tidak melihat data rekan atau draft performa

3.2 Capability Registry Baseline

Domain	Capability
Organization	organization.read; organization.configure
Revenue	revenue.read; revenue.import; revenue.reconcile
Target	target.read; target.propose; target.approve; target.reopen
Performance	performance.read; performance.assess; performance.approve; performance.reopen
Workforce	workforce.read.scope; workforce.read.self; workforce.import
Payroll	payroll.summary.read
Reporting	reporting.cross_division; reporting.export
Audit	audit.read

3.3 Scope Algorithm

1. Bangun principal dari sesi yang telah terverifikasi.
2. Resolve capability dari role assignment aktif.
3. Resolve division/outlet/employee scope dari assignment efektif pada periode request.
4. Iris filter request dengan scope principal; jangan memperluas scope dari parameter client.
5. Tolak cross-scope sebagai SCOPE_VIOLATION dan catat audit keamanan tanpa payload sensitif.

4. Session, Context & Organization APIs

Method	Path	Capability	Contract ringkas
GET	/session/me	authenticated	Principal, role, capability, assignment aktif, default context
POST	/session/logout	authenticated	Akhiri sesi; mekanisme token/cookie mengikuti keputusan auth
GET	/divisions	organization.read	Hanya divisi dalam scope; BOD dapat seluruh divisi
GET	/divisions/{id}/outlets	organization.read	Outlet aktif dan scoped
GET	/employees	workforce.read.scope	Daftar terbatas; filter outlet/status; tanpa payroll
GET	/employees/me	workforce.read.self	Identity karyawan yang terhubung ke user

GET /SESSION/ME

```
{
  "data": {
    "user": { "id": "uuid", "display_name": "Manager Demo" },
    "roles": ["MANAGER"],
    "capabilities": ["revenue.read", "revenue.import", "target.propose"],
    "scope": { "division_ids": ["uuid"], "outlet_ids": ["uuid", "uuid"], "employee_id": null },
    "default_context": { "division_id": "uuid", "outlet_id": null }
  },
  "meta": { "trace_id": "uuid" }
}
```

DATA MINIMIZATION

Endpoint konteks tidak mengirim password hash, token, NIK, rekening, salary, atau detail kontrak yang tidak diperlukan oleh layar.

5. Reporting & Dashboard APIs

Method	Path	Capability	Contract ringkas
GET	/dashboards/manager	reporting scoped	KPI Manager untuk satu divisi/periode; outlet opsional
GET	/dashboards/bod	reporting.cross_division	Overview lintas divisi; hanya metric kompatibel
GET	/reports/outlets	reporting scoped	Ranking dan drill-down outlet
GET	/reports/revenue-trend	revenue.read	Time series + tabel alternatif
GET	/reports/workforce-summary	workforce.read.scope	Agregat read-only sesuai scope

```
GET /api/v1/dashboards/manager?period=2026-08&division_id={uuid}&outlet_id={uuid?}

{
  "data": {
    "context": { "division_id": "uuid", "outlet_id": null, "period": "2026-08" },
    "kpis": [
      { "code": "GROSS_REVENUE", "value": "125000000.00", "currency": "IDR", "level": "DIVISION", "status": "AVAILABLE" },
      { "code": "TARGET_ACHIEVEMENT", "value": null, "unit": "PERCENT", "status": "NOT_AVAILABLE" }
    ],
    "outlet_ranking": [], "workforce_summary": null, "performance_summary": null
  },
  "meta": { "trace_id": "uuid", "data_period": "2026-08", "source": "EXCEL", "last_synced_at": "...", "completeness": "PARTIAL" }
}
```

5.1 Aggregation Guardrails

- Persentase outlet tidak boleh dirata-ratakan; hitung dari numerator/denominator agregat.
- Target nol menghasilkan N/A, bukan pembagian nol.
- Null, zero, partial, stale, dan not_available adalah keadaan berbeda.
- Perbandingan lintas divisi hanya untuk metric dengan level, unit, formula, dan version yang kompatibel.

6. Revenue Import APIs

Method	Path	Capability	Contract ringkas
POST	/revenue/imports	revenue.import	Upload private Excel; buat batch UPLOADED
GET	/revenue/imports	revenue.import	Riwayat scoped + status/counts
GET	/revenue/imports/{id}	revenue.import	Metadata, mapping, validation summary
POST	/revenue/imports/{id}/validate	revenue.import	Parse + validate staging; idempotent
GET	/revenue/imports/{id}/rows	revenue.import	Preview valid/invalid dengan pagination
GET	/revenue/imports/{id}/error-report	revenue.import	Unduh report aman; signed/private access
POST	/revenue/imports/{id}/post	revenue.import	Atomic post; Idempotency-Key wajib
POST	/revenue/imports/{id}/cancel	revenue.import	Hanya state yang diizinkan; alasan wajib bila dipakai

```
POST /api/v1/revenue/imports
Content-Type: multipart/form-data

file=<xlsx>
division_id=uuid
period_type=DAILY|MONTHLY
period_start=2026-08-01
period_end=2026-08-31
template_version=OPEN_DECISION
```

RESPONSE

```
{
  "data": {
    "id": "uuid", "status": "UPLOADED", "file_name": "revenue-2026-08.xlsx",
    "period_type": "DAILY", "row_counts": { "total": 0, "valid": 0, "invalid": 0 },
    "checksum": "sha256:..."
  },
  "meta": { "trace_id": "uuid" }
}
```

PRIVATE FILE RULE

File tidak boleh memiliki URL publik permanen. Validasi extension, MIME, signature, ukuran, checksum, dan izin akses sebelum parser dijalankan.

7. Revenue Validation & Posting Contract

7.1 Canonical Row

Field	Type	Rule
outlet_code	string	Wajib; resolve ke outlet aktif dalam scope
business_date	YYYY-MM-DD	Wajib untuk daily
period_month	YYYY-MM	Wajib untuk monthly
gross_revenue	decimal string	Non-negative; formula final OPEN
net_revenue	decimal string	Non-negative; formula final OPEN
currency	ISO code	Baseline IDR; perlu keputusan perusahaan
source_row_number	integer	Wajib untuk pelacakan error

7.2 Row Error

```
{
  "row_number": 24,
  "column": "outlet_code",
  "value": "OUT-99",
  "code": "OUTLET_NOT_FOUND",
  "message": "Kode outlet tidak ditemukan atau tidak aktif.",
  "suggested_fix": "Gunakan kode outlet aktif dalam scope divisi."
}
```

7.3 Posting Transaction

1. Periksa capability, scope, status batch, checksum, dan idempotency key.
2. Kunci batch atau gunakan transaksi untuk mencegah double post.
3. Tulis canonical facts dan lineage dalam satu transaction.
4. Jika satu operasi gagal, rollback seluruh posting; jangan menulis fakta parsial.
5. Ubah status ke POSTED dan catat counts serta audit event setelah commit.
6. Koreksi memakai superseded batch/reversal, bukan overwrite histori.

BLOCKED SEBAGIAN

Template kolom dan rumus gross/net belum final. Parser boleh memakai fixture berlabel demo, tetapi contract produksi tidak boleh dianggap LOCKED.

8. Reconciliation APIs

Method	Path	Capability	Contract ringkas
GET	/reconciliations	revenue.reconcile	Queue scoped; filter period/outlet/status
GET	/reconciliations/{id}	revenue.reconcile	Daily total, monthly total, difference, lineage
POST	/reconciliations/{id}/confirm	revenue.reconcile	Konfirmasi selisih; reason wajib bila berbeda
POST	/reconciliations/{id}/lock	revenue.reconcile	Kunci hasil setelah syarat terpenuhi

```
{
  "data": {
    "id": "uuid", "outlet_id": "uuid", "period_month": "2026-08",
    "daily_total": { "gross": "125000000.00", "net": "112000000.00", "currency": "IDR" },
    "monthly_total": { "gross": "124500000.00", "net": "111500000.00", "currency": "IDR" },
    "difference": { "gross": "500000.00", "net": "500000.00" },
    "status": "NEEDS_CONFIRMATION", "reason": null
  },
  "meta": { "trace_id": "uuid", "source": "EXCEL", "completeness": "COMPLETE" }
}

POST /api/v1/reconciliations/{id}/confirm
{
  "reason": "Rekap bulanan belum memasukkan transaksi penutupan tanggal 31.",
  "version": 3
}
```

STATE MACHINE

OPEN -> MATCHED atau NEEDS_CONFIRMATION -> CONFIRMED -> LOCKED. Client tidak boleh mengirim status bebas melalui PATCH.

9. Revenue Target APIs

Method	Path	Capability	Contract ringkas
POST	/targets	target.propose	Draft target per outlet/period/metric/version
GET	/targets	target.read	Scoped list + approval status
GET	/targets/{id}	target.read	Detail + derived division total + history
PATCH	/targets/{id}	target.propose	Hanya DRAFT/RETURNED dan creator scope
POST	/targets/{id}/submit	target.propose	Validasi lengkap; menjadi SUBMITTED
POST	/targets/{id}/approve	target.approve	BOD; append-only approval; lock
POST	/targets/{id}/return	target.approve	BOD; note wajib
POST	/targets/{id}/reopen	target.reopen	Privileged; reason dan audit wajib

```

POST /api/v1/targets
{
  "outlet_id": "uuid",
  "period_month": "2026-09",
  "metric_type": "NET_REVENUE",
  "value": "150000000.00",
  "currency": "IDR"
}

POST /api/v1/targets/{id}/return
{ "note": "Target outlet M-02 perlu disesuaikan dengan kapasitas operasional.", "version": 1 }

```

9.1 Workflow Rules

- Manager mengusulkan target outlet; target divisi dihitung dari outlet approved.
- BOD approve/return, bukan mengedit nilai secara langsung.
- Pembuat tidak boleh menyetujui record sendiri; Superadmin tidak bypass aturan ini.
- Approval, return, reopen, actor, note, dan occurred_at bersifat append-only.

10. Performance APIs

Method	Path	Capability	Contract ringkas
GET	/performance/templates	performance.assess	Template aktif sesuai divisi/periode
POST	/performance/assessments	performance.assess	Draft penilaian employee scoped
GET	/performance/assessments	performance.read	List sesuai role/scope/status
GET	/performance/assessments/{id}	performance.read	Detail score + workflow history sesuai izin
PATCH	/performance/assessments/{id}	performance.assess	Edit hanya DRAFT/RETURNED
POST	/performance/assessments/{id}/submit	performance.assess	Hitung server-side; menjadi SUBMITTED
POST	/performance/assessments/{id}/approve	performance.approve	BOD; final + locked
POST	/performance/assessments/{id}/return	performance.approve	BOD; note wajib
GET	/performance/results/me	performance.read	User hanya hasil final yang diizinkan

ASSESSMENT REQUEST

```
{
  "employee_id": "uuid",
  "period_month": "2026-08",
  "template_id": "uuid",
  "template_version": 1,
  "scores": [
    { "indicator_id": "uuid", "score": "4.00", "note": "Bukti penilaian terlampir pada proses internal." }
  ]
}
```

BLOCKED BISNIS

Definisi KPI, unit, bobot, range, dan effective period harus disetujui sebelum weighted score final. Total bobot template aktif wajib 100%.

P0 RULE

Omzet outlet tidak otomatis menjadi nilai performa individu. BOD tidak boleh mengubah skor; hanya approve atau return.

11. SobatHR & Workforce APIs

Method	Path	Capability	Contract ringkas
POST	/hr/imports	workforce.import	Upload ekspor SobatHR per domain; HRD primary
GET	/hr/imports	workforce.import	History, counts, source, freshness
POST	/hr/imports/{id}/validate	workforce.import	Validate mapping + employee resolution
GET	/hr/imports/{id}/rows	workforce.import	Staging preview; payload sensitif dimasking
POST	/hr/imports/{id}/publish	workforce.import	Publish canonical facts; last valid remains on failure
GET	/workforce/summary	workforce.read.scope	Attendance/leave/overtime/sickness aggregates
GET	/workforce/employees/{id}	workforce.read.scope/self	Read-only HR status; no payroll
GET	/workforce/me	workforce.read.self	User self-view; no mutation/action

Domain	Minimal response	Privacy rule
Attendance	scheduled/actual, status, lateness summary	Tidak menampilkan lokasi mentah bila tidak diperlukan
Leave/permission	type, period, status aggregate	Tidak ada approve/edit
Overtime	hours and trend	Tidak ada pengajuan/edit
Sickness	status/aggregate	Tidak ada diagnosis atau detail medis
Contract	status, start/end, reminder	Read-only; field sesuai kebijakan

BLOCKED

Path dapat dibuat sebagai interface, tetapi DTO vendor, mapping, idempotency final, dan publish logic belum READY sampai contoh ekspor anonim SobatHR tersedia.

ADAPTER RULE

SobatHrImportAdapter dan SobatHrApiAdapter menghasilkan canonical DTO yang sama. Domain service dan UI tidak boleh bergantung pada nama kolom vendor.

12. Payroll & BOD APIs

Method	Path	Capability	Contract ringkas
GET	/payroll/summary	payroll.summary.read	BOD-only aggregate per period/division
GET	/dashboards/bod	reporting.cross_division	Revenue, target, performance, workforce risk
GET	/approvals	target/performance approve	Unified approval queue untuk BOD
GET	/reports/cross-division	reporting.cross_division	Metric compatible only
POST	/reports/exports	reporting.export	Scoped async export + audit

```
GET /api/v1/payroll/summary?period=2026-08&division_id={uuid?}
```

```
{
  "data": {
    "period_month": "2026-08",
    "currency": "IDR",
    "company_total": null,
    "divisions": [],
    "status": "NOT_AVAILABLE"
  },
  "meta": { "trace_id": "uuid", "source": "SOBATHR_FILE", "last_synced_at": null, "completeness": "MISSING" }
}
```

12.1 Hard Privacy Constraints

- Tidak ada endpoint employee-level payroll.
- Tidak ada nama, NIK, rekening, slip gaji, atau komponen individu pada response/export.
- Manager, HRD, User, dan Superadmin tanpa capability eksplisit ditolak server-side.
- Missing/partial tidak diganti angka nol.
- Nilai payroll tidak boleh muncul pada URL, log, trace, error report, fixture, atau screenshot.

BLOCKED

Field agregat payroll belum ditentukan. Gunakan response kosong berstatus NOT_AVAILABLE/MISSING sampai HRD dan BOD menyetujui komponennya.

13. Error, Audit & Observability

13.1 Error Code Registry

HTTP	Code	Kapan digunakan
400	VALIDATION_ERROR	Field/request tidak valid
401	AUTH_REQUIRED	Principal tidak tersedia/invalid
403	FORBIDDEN_CAPABILITY	Capability tidak dimiliki
403	SCOPE_VIOLATION	Entity di luar assignment/scope
404	RESOURCE_NOT_FOUND	Resource tidak ada atau tidak boleh diungkap
409	INVALID_STATE_TRANSITION	Aksi tidak valid untuk status saat ini
409	VERSION_CONFLICT	Record telah berubah
409	IDEMPOTENCY_CONFLICT	Key sama dengan payload berbeda
422	IMPORT_ROW_INVALID	Batch memiliki row invalid
422	APPROVAL_SELF_ACTION_DENIED	Creator mencoba self-approve
422	SOURCE_DATA_UNAVAILABLE	Sumber belum tersedia/complete
429	RATE_LIMITED	Batas request terlampaui
500	INTERNAL_ERROR	Error tak terduga; message aman

13.2 Audit Event Minimum

```
{
  "event_id": "uuid", "event_type": "TARGET_APPROVED", "occurred_at": "ISO-8601",
  "actor_user_id": "uuid", "actor_role": "BOD",
  "entity_type": "RevenueTarget", "entity_id": "uuid",
  "division_id": "uuid", "outlet_id": "uuid|null",
  "request_id": "uuid", "reason": null,
  "before_hash": "...", "after_hash": "..."
}
```

SANITASI

Audit menyimpan siapa, apa, kapan, scope, dan alasan; bukan seluruh payload. Gunakan hash atau metadata untuk perubahan sensitif.

13.3 Minimum Observability

- Structured log dengan trace_id/request_id dan error code.
- Metric request rate, latency, error rate, queue/import failure, dan posting duration.
- Alert untuk auth anomaly, repeated scope violation, import failure, dan job stuck.
- Health endpoint tidak membuka secret, dependency credential, atau detail jaringan.

14. AI Coding Instructions

CORE INSTRUCTION

AI adalah pelaksana task, bukan pembuat keputusan bisnis. AI wajib menunjukkan asumsi, dependency, dan test sebelum mengubah kode.

14.1 Wajib Sebelum Coding

1. Sebutkan Backlog ID dan dokumen/bagian yang menjadi sumber.
2. Daftar file yang akan dibuat atau diubah.
3. Jelaskan module owner, endpoint, request/response, capability, dan scope.
4. Jelaskan migration/constraint/transaction bila menyentuh data.
5. Petakan automated test dan UAT Case ID.
6. Tandai field, enum, formula, source mapping, atau permission yang belum sah sebagai OPEN/BLOCKED.

14.2 Larangan

- Jangan menambah field, enum, role, capability, formula, atau status dari tebakan.
- Jangan memakai Prisma Studio sebagai panel admin produksi.
- Jangan hanya membuat FE guard; semua policy dan scope wajib server-side.
- Jangan membuat generic PATCH status untuk workflow bisnis.
- Jangan overwrite histori import, approval, assessment, atau reconciliation.
- Jangan menyimpan data asli karyawan/payroll pada seed, fixture, screenshot, log, atau commit.
- Jangan melakukan refactor lintas modul di luar scope task tanpa izin.

14.3 Output AI yang Diharapkan

1. Scope dan Backlog ID
2. Sources dan keputusan yang dipakai
3. Assumptions / OPEN / BLOCKED
4. Files to change
5. Contract: endpoint, DTO, permission, scope, state, error
6. Implementation
7. Tests dan UAT mapping
8. Verification result
9. Remaining risks

15. Module Prompt Pack

15.1 Foundation / Organization

Kerjakan [FND/ORG BACKLOG ID] mengikuti seluruh baseline dokumen. Implementasikan NestJS /api/v1, error envelope, trace_id, Prisma migration, capability policy, dan effective assignment scope. Tampilkan allow/deny tests untuk BOD, Superadmin, HRD, Manager, dan User. Jangan menetapkan mekanisme auth produksi tanpa decision log.

15.2 Revenue Import / Reconciliation

Kerjakan [REV BACKLOG ID]. Implementasikan private upload -> staging -> validation -> preview -> atomic post -> reconciliation. Gunakan Decimal string, UUID, checksum, idempotency key, transaction, lineage, row error contract, dan audit. Jangan mengunci template atau rumus gross/net yang masih OPEN.

15.3 Dashboard / Reporting

Kerjakan [DASH/BOD BACKLOG ID]. Buat read model server-side dengan period, source, last_synced_at, completeness, scope, dan metric compatibility. Implementasikan loading/empty/partial/stale/error/no-access di React. Jangan mengganti missing dengan zero atau merata-ratakan persentase outlet.

15.4 Target / Performance

Kerjakan [TGT/PERF BACKLOG ID]. Gunakan command submit/approve/return/reopen, append-only approval, version conflict handling, self-approval denial, BOD-only approval, lock, audit, dan negative tests. Jangan memberi BOD direct edit atau mengubah omzet outlet menjadi skor individu.

15.5 SobatHR / Payroll

Kerjakan [HR BACKLOG ID]. Pertahankan adapter boundary dan canonical DTO. HR data read-only; payroll summary BOD-only dan tanpa employeeId. Gunakan fixture anonim. Jika contoh ekspor atau aturan agregasi belum tersedia, implementasikan interface/placeholder dan tandai BLOCKED; jangan menebak mapping.

PROMPT RULE

Satu prompt = satu Backlog ID atau satu use case sempit. Bila task terlalu besar, pecah berdasarkan migration, service, endpoint, UI, dan test.

16. Implementation & Review Gates

16.1 Backend Gate

- Controller hanya transport; business rule berada di application/domain service.
- DTO tervalidasi; unknown field policy ditetapkan; money memakai Decimal/string.
- Policy dan scope dieksekusi sebelum query/write.
- Prisma query selalu scoped; onDelete, index, unique, dan transaction eksplisit.
- Workflow memakai command method; invalid transition diuji.
- Audit ditulis setelah aksi berhasil; payload sensitif disanitasi.

16.2 Frontend Gate

- Client memakai typed contract dari packages/contracts atau generated types.
- Filter periode/divisi/outlet tersimpan di URL dan tidak menawarkan scope ilegal.
- Loading, empty, partial, stale, error, success, locked, dan no-access tersedia.
- Status menggunakan teks/ikon; chart memiliki tabel atau ringkasan alternatif.
- Error menampilkan pesan tindakan dan trace/reference code, bukan pesan teknis mentah.

16.3 Test Gate

Layer	Minimum proof
Unit	Formula, validator, state transition, policy decision
Integration	Prisma constraints, transaction rollback, idempotency, audit
API	Envelope, status code, field error, scope allow/deny
UI	All states, keyboard/focus, permission variants
E2E/UAT	Backlog acceptance dan UAT Case ID terkait

P0 RELEASE GATE

Tidak boleh ada kebocoran payroll, cross-scope access, data korup, approval bypass, atau audit kritis yang hilang.

17. Coding Start Checklist

17.1 Ready Now

- Monorepo TypeScript, React app shell, NestJS /api/v1, error envelope, trace_id.
- Prisma/PostgreSQL baseline, migration workflow, role/capability/scope tests.
- Organization/outlet/current context contract dengan seed anonim.
- Dashboard UI dengan mock typed contract dan seluruh screen states.
- Revenue import UI/parser fixture sepanjang diberi label demo dan tidak dianggap final.
- Workflow engine generik untuk explicit commands, audit, dan optimistic conflict.

17.2 Must Not Be Finalized Yet

- Rumus dan template omzet sebelum Finance/Business menyetujui.
- KPI dan weighted score sebelum BOD/Manager menyetujui template efektif.
- SobatHR DTO mapping sebelum contoh ekspor anonim tersedia.
- Payroll fields sebelum BOD/HRD menyetujui agregat yang boleh terlihat.
- Production auth, storage, queue, retention, RPO/RTO, dan SLA sebelum keputusan teknis/operasional.

17.3 First Coding Command

Kerjakan FND-01. Buat monorepo TypeScript dengan apps/web, apps/api, dan packages/contracts. Sebelum coding, tampilkan struktur file, scripts lint/typecheck/test/build, dependency yang dipilih, serta alasan singkat. Jangan implementasikan fitur bisnis. Hasil harus dapat dijalankan lokal dan di CI tanpa secret produksi.

DOKUMEN SET SELESAI

PRD, UI/UX, ARD, Data Dictionary, UAT, Backlog, dan API Contract kini membentuk baseline lengkap untuk mulai coding. Perubahan berikutnya dikelola sebagai decision log dan versi dokumen, bukan edit tanpa jejak.